

Mohammed VI Polytechnic University (UM6P)

Internship Report

Secure Development of a Building Analytics Dashboard

Completed at:
Green Energy Park, Benguerir, Morocco

Student: BENFELLAH Ikram
Supervisor: Oualid Mghazli and Laila LIMNI
Duration: 10 June - 10 August 2025 (2 months)

September 10, 2025



Contents

Introduction	2
1 Presentation of the Organization	3
1.1 Field of Activity	3
1.2 Organizational Structure	3
1.3 Professions Present	3
2 Internship Work and Contribution	5
2.1 Project Context	5
2.2 Problems, Solutions, and Implemented Improvements	5
2.2.1 User Authentication and Authorization	5
2.2.2 Session Management	5
2.2.3 Input Validation and Sanitization	6
2.2.4 Audit Logging	6
2.2.5 Data Isolation	7
2.2.6 Secure Deployment Configuration	7
2.3 Summary of Implemented Security Features	8
Conclusion	9
Bibliography	10

Introduction

This report details the work accomplished during my two-month internship at the Green Energy Park (GEP) in Benguerir, Morocco. The primary objective was to transition a Building Analytics Dashboard, developed using the Streamlit framework, from a functional prototype to a secure, production-ready application. The project focused on identifying critical security vulnerabilities inherent in the initial version and implementing robust solutions to mitigate them. This internship provided invaluable hands-on experience in cybersecurity principles, secure software development lifecycles (SDLC), and DevOps practices.

Chapter 1

Presentation of the Organization

1.1 Field of Activity

The Green Energy Park is a pioneering research, development, and innovation platform specializing in renewable energies, energy efficiency, and smart sustainable technologies. Strategically located in Benguerir, Morocco, it stands as the first platform of its kind in Africa. Its core mission is to bridge the gap between academic research and industrial application, fostering innovation, promoting applied research, and supporting national and regional strategies for energy transition. The GEP provides a unique ecosystem where researchers, engineers, and industry partners collaborate to develop and test cutting-edge technologies in real-world conditions.

1.2 Organizational Structure

The Green Energy Park operates under a agile, project-oriented structure that encourages cross-departmental collaboration. Its organization is composed of several key divisions:

- **Research & Development:** Focused on fundamental and applied research in solar PV, smart grids, and energy storage.
- **Innovation & Technology Transfer:** Dedicated to prototyping, pilot projects, and commercializing research outcomes.
- **Technical Operations:** Manages the state-of-the-art testing facilities and laboratory infrastructure.
- **Software & Data Analytics:** Develops digital tools, platforms, and dashboards (like the one in this project) to monitor, analyze, and optimize energy systems.

This structure facilitates a multidisciplinary approach to solving complex energy challenges.

1.3 Professions Present

The center employs a diverse team of professionals, creating a dynamic and knowledge-rich environment. Key roles include:

- Research Scientists and Post-Docs
- Electrical and Energy Engineers
- Software Developers and Data Scientists
- Project Managers and Innovation Specialists
- Lab Technicians and Technical Support Staff

Working alongside these experts provided a comprehensive understanding of how software solutions are integral to modern energy research.

Chapter 2

Internship Work and Contribution

2.1 Project Context

The Building Analytics Dashboard is a web application designed to visualize and analyze energy consumption, indoor environmental quality, and overall performance of buildings within the GEP campus. Built with Streamlit for rapid prototyping, the initial version prioritized functionality over security. My mission was to conduct a security audit and implement essential security measures to protect sensitive data and ensure system integrity, transforming it into a reliable tool for internal stakeholders.

2.2 Problems, Solutions, and Implemented Improvements

2.2.1 User Authentication and Authorization

Problem: Streamlit provides no built-in mechanism for user authentication or role-based access control (RBAC). The application was effectively open to anyone with the URL, posing a significant risk of unauthorized data access.

Solution: I designed and implemented a custom authentication system. User credentials (username + salted password) were hashed using the SHA-256 algorithm and stored securely in a PostgreSQL database. Furthermore, I integrated an RBAC system, defining roles such as `admin`, `researcher`, and `demo` with distinct permissions.

Improvement: This ensured that only authenticated users could access the platform, and their access level was strictly limited to their role's permissions, significantly reducing the risk of data breaches.

2.2.2 Session Management

Problem: The application lacked session controls. A logged-in session could remain active indefinitely on a device, increasing the risk of unauthorized access if the device was left unattended. There was also no protection against Cross-Site Request Forgery (CSRF).

Solution: I developed a custom session management layer. Each successful login generated a unique session token with a strict expiration time (e.g., 60 minutes). The system automatically invalidates the token upon logout or timeout.

Improvement: This mitigated the risk of session hijacking and ensured users are periodically re-authenticated, enhancing overall application security.

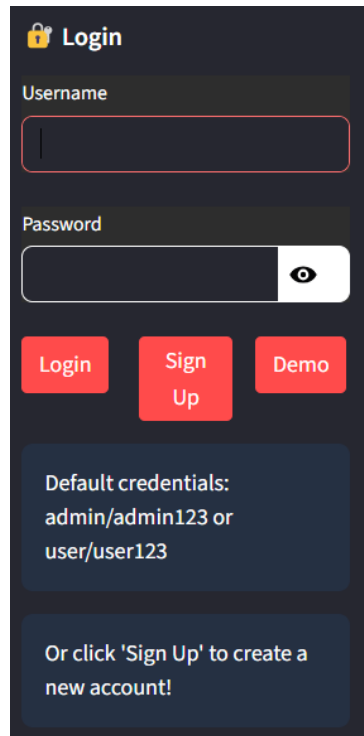


Figure 2.1. Implemented login interface for user authentication.

2.2.3 Input Validation and Sanitization

Problem: The dashboard allowed file uploads (e.g., CSV data files) and user inputs without proper validation, creating vulnerabilities for SQL Injection, Cross-Site Scripting (XSS), and malicious file execution.

Solution: I implemented stringent server-side validation:

- For file uploads: Validation against a predefined CSV schema (checking columns, data types).
- For database queries: Used parameterized queries to completely eliminate SQL injection risks.
- For user inputs: Implemented output escaping to prevent XSS attacks.

Improvement: The application became resilient to common injection attacks, ensuring the integrity of both the application and the underlying database.

2.2.4 Audit Logging

Problem: There was no traceability of user actions within the application. In case of an error or a security incident, it was impossible to determine who did what and when.

Solution: I developed a comprehensive audit logging system that records crucial user activities into a dedicated database table. Logged events include:

- User login and logout attempts (success/failure).
- File uploads and data processing actions.
- Access to specific analytical models or sensitive data views.

Improvement: This provided a clear audit trail for accountability, security monitoring, and debugging purposes.

2.2.5 Data Isolation

Problem: Initially, all users potentially had access to all uploaded datasets, creating a critical data privacy issue.

Solution: I implemented a data isolation mechanism. Upon creation, each user is assigned a unique directory. All their uploaded files and processed data are stored within this directory. Every data access request is validated against the user's session to ensure they can only access their own data.

Improvement: This guaranteed strict data privacy and prevented horizontal privilege escalation between users.

```
{
  "city1": {
    "owner": "admin",
    "uploaded_at": "2025-09-08 22:58:00",
    "processed_with": "flexible"
  },
  "city2": {
    "owner": "user",
    "uploaded_at": "2025-09-08 22:58:00",
    "processed_with": "standard_processing"
  }
}
```

Figure 2.2. Example of ownership of datasets.

2.2.6 Secure Deployment Configuration

Problem: Application secrets (database passwords, API keys) were hardcoded in the source code, a severe security anti-pattern. The Streamlit configuration was also left in its default, insecure state.

Solution:

- I migrated all sensitive credentials to environment variables and Streamlit's secrets management file (`secrets.toml`), which is never committed to version control.

- I configured critical Streamlit server settings: enabled Cross-Site Request Forgery (XSRF) protection, disabled Cross-Origin Resource Sharing (CORS), and set the browser to use HTTPS only.

Improvement: This eliminated the risk of secret leakage and hardened the application's deployment environment against common web attacks.

2.3 Summary of Implemented Security Features

The following table provides a consolidated overview of the key security improvements made during the internship.

Feature	Problem	Solution	Outcome
Authentication & Authorization	No user management or access control.	Custom auth with SHA-256 + Salt, PostgreSQL, RBAC.	Secure, multi-user, role-based access.
Session Management	No session expiration or CSRF protection.	Custom session handling with timeout logic.	Reduced risk of session hijacking.
Input Validation	Vulnerable to Injection, XSS, malicious uploads.	CSV schema validation, parameterized queries, output escaping.	Secure data ingestion and processing.
Audit Logging	No traceability of user actions.	Comprehensive logging of logins, uploads, and model runs.	Accountability and anomaly detection.
Data Isolation	Risk of data leakage between users.	User-specific directories with access checks.	Guaranteed data privacy and confidentiality.
Secure Deployment	Hardcoded secrets, insecure default config.	Environment variables, XSRF protection, HTTPS.	Production-ready, secure deployment.

Table 2.1. Summary of Security Features Implemented

Conclusion

This two-month internship at the Green Energy Park was an immensely valuable experience that allowed me to apply theoretical cybersecurity knowledge to a real-world, impactful project. I successfully transformed a vulnerable prototype into a secure, production-grade application by implementing critical features such as a robust authentication and authorization system, secure session management, input validation, audit logging, and data isolation.

Beyond the technical deliverables, I gained profound insights into the secure software development lifecycle (SDLC) and the challenges of deploying data-sensitive applications in a research environment. This internship solidified my passion for cybersecurity and provided me with practical skills that are directly applicable to my future career. I am grateful to my supervisor Walid for this chance and for providing an environment that fosters learning and innovation.

Bibliography

- [1] Streamlit Inc., "Streamlit Documentation," 2023. [Online]. Available: <https://docs.streamlit.io/>
- [2] OWASP Foundation, "OWASP Top Ten Web Application Security Risks," 2021. [Online]. Available: <https://owasp.org/www-project-top-ten/>
- [3] The PostgreSQL Global Development Group, "PostgreSQL 15.2 Documentation," 2023. [Online]. Available: <https://www.postgresql.org/docs/>
- [4] Singh, K., & Gupta, P., "Secure Authentication and Session Management in Web Applications," *Journal of Network and Computer Applications*, vol. 108, pp. 1-12, 2018.

Internship Report – Green Energy Park

Secure Development of a Building Analytics Dashboard

Prepared by:

BENFELLAH Ikram

Supervised by:

Oualid Mghazli and Laila LIMNI

Benguerir, Morocco

10 June - 10 August 2025